



IntroToBurp

IntroToBurp 



Easy

Web Exploitation

picoCTF 2024

AUTHOR: NANA AMA ATOMBO-SACKY & SABINE GISAGARA

Description

Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.

Its current status is:

NOT_RUNNING

Launch Instance

Hints 

1 2

Try using burpsuite to intercept request to capture the flag.

41,060 users solved



49%



Liked

 picoCTF{FLAG}

Submit
Flag

Author: The Analyst: Hyposelenia

Challenge: IntroToBurp

Category: Web Exploitation

Date: 02/23/26



I. Objective

The objective of this challenge is to **learn how to intercept, view, and modify web requests using Burp Suite**, and to understand how insecure authentication logic—specifically OTP verification—can be bypassed when handled improperly on the client side.

II. Background

Modern websites communicate with servers using **HTTP requests**. When users log in, submit forms, or enter OTP codes, these actions are sent to the server as requests.

Normally, users:

- Cannot see these requests
- Cannot modify them

Burp Suite is a tool that allows security analysts to:

- Intercept web traffic
- Inspect requests and responses
- Modify data before it reaches the server

This challenge introduces Burp Suite in a beginner-friendly way and demonstrates how **weak OTP validation** can be exploited.

III. Tool Used

- **Oracle VirtualBox (Kali Linux)** - Used as the penetration testing environment
- **Burp Suite** - Used to intercept, analyze, and modify web traffic
- **Built-in Chromium Browser (Burp)** - Used to browse the target website through Burp's proxy



IV. Methodology

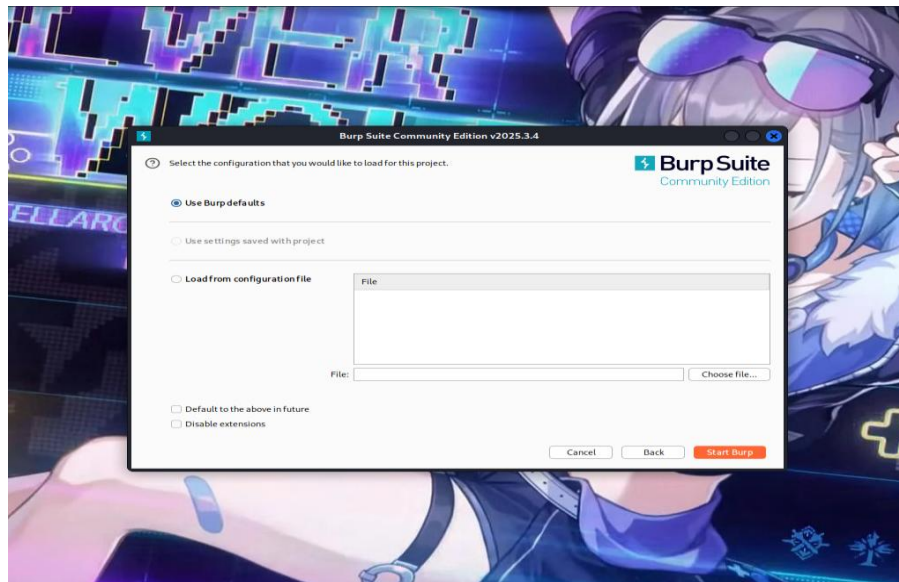
1. Launched the challenge instance

Its current status is:

NOT_RUNNING

Launch Instance

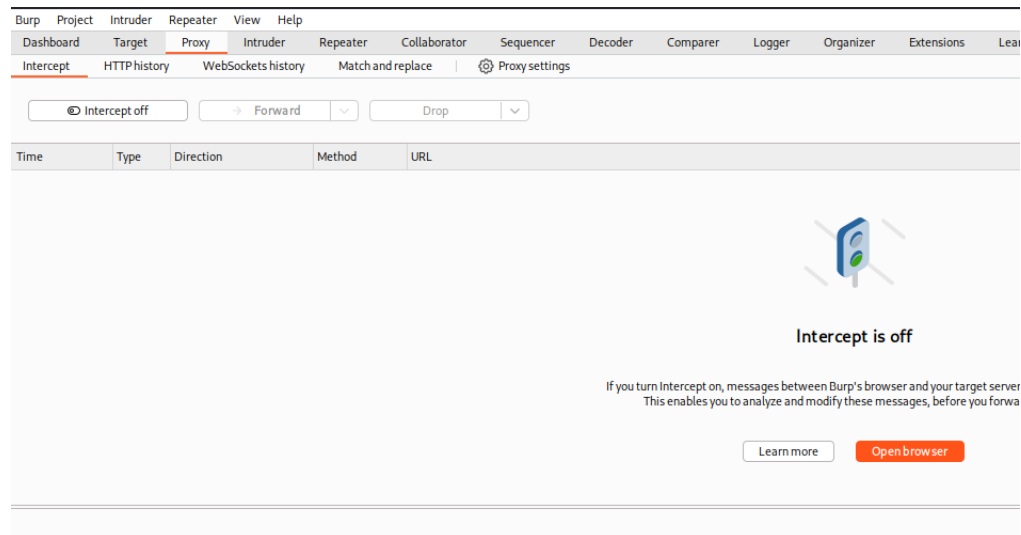
2. Opened Kali Linux in Oracle VirtualBox
3. Launched **Burp Suite**



4. Navigated to the **Proxy** tab



Saint Columban College
College of Computing Studies
Pagadian City

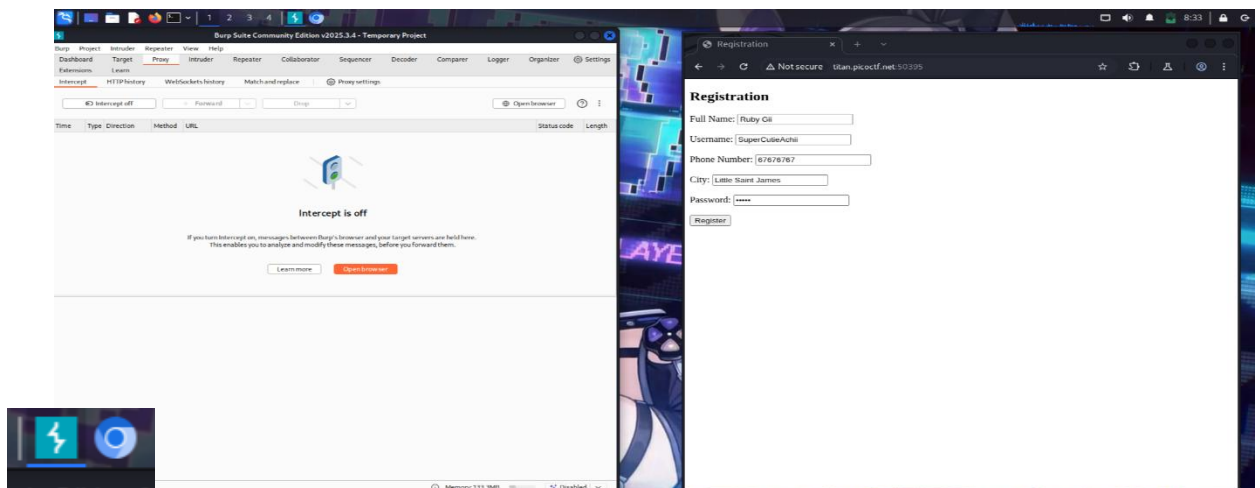


5. Ensured **Intercept was OFF**, then clicked **Open Browser**



6. Used Burp's Chromium browser to **access the challenge URL**

(This opens after clicking “Open browser”, it's like chrome and you'll read portswagger)





Saint Columban College
College of Computing Studies
Pagadian City



7. Entered random credentials to register

Registration

Full Name: Ruby Gii

Username: SuperCutieAchii

Phone Number: 67676767

City: Little Saint James

Password: *****

Register

8. Turned **Intercept** ON before submitting the credentials

(Look at the left side, that will appear once you register)

Intercept

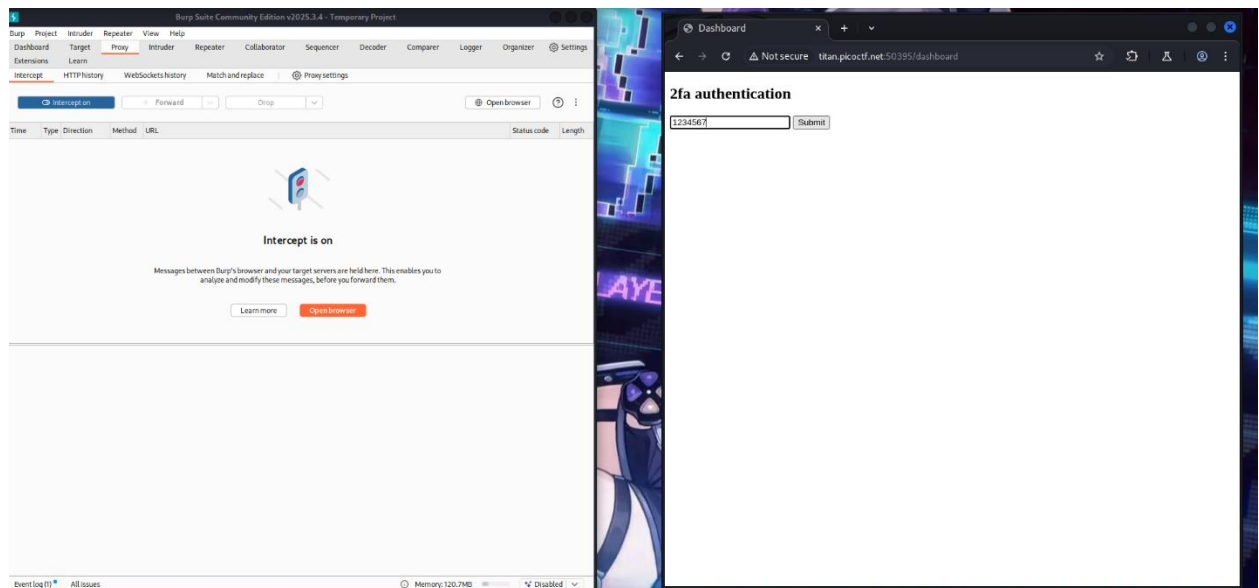
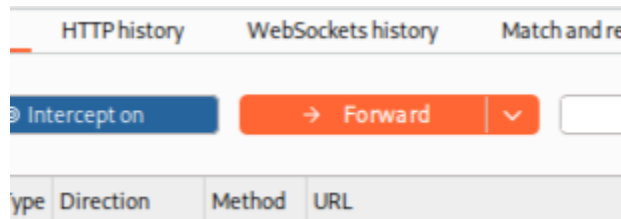
Request to http://titan.picoctf.net/register/

Request details:

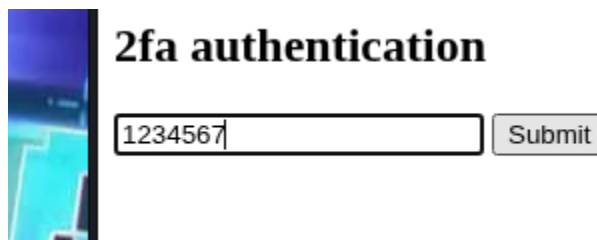
- Method: POST
- URL: http://titan.picoctf.net/register/
- Request body parameters:
- Request body:



9. Forwarded **intercepted requests** until reaching the **OTP verification** page



10. Entered a random OTP and submitted

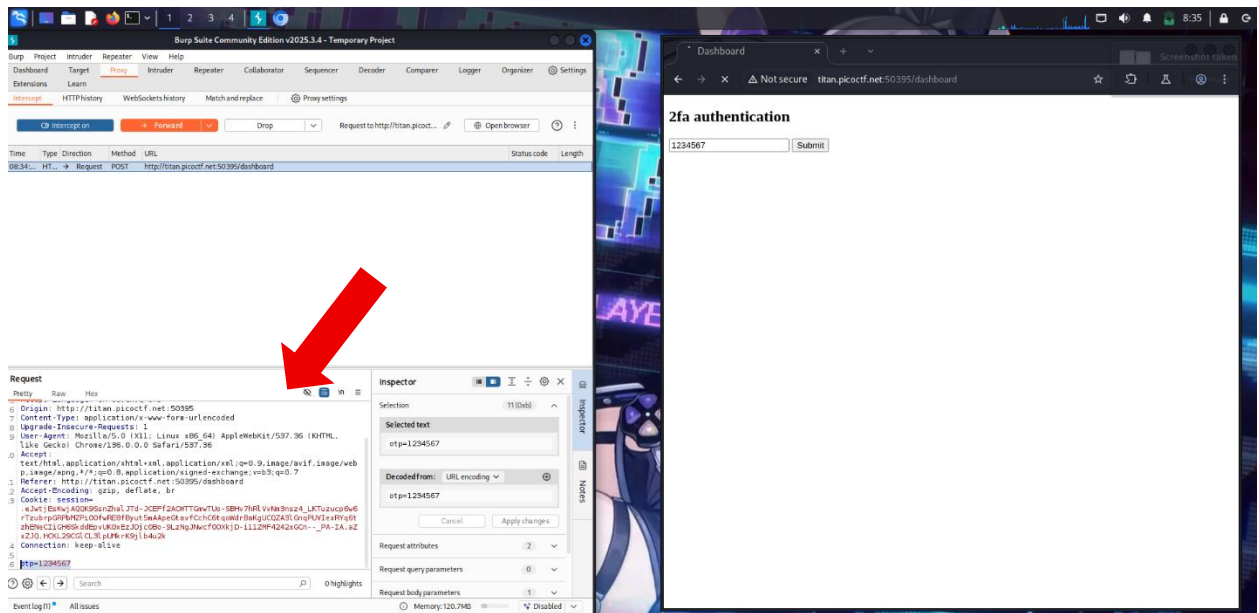


11. Intercepted the OTP request (Click submit)

12. **Removed the OTP parameter** from the request

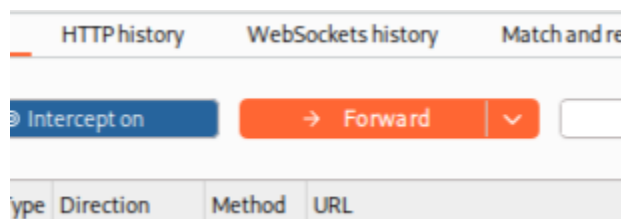


Saint Columban College
College of Computing Studies
Pagadian City



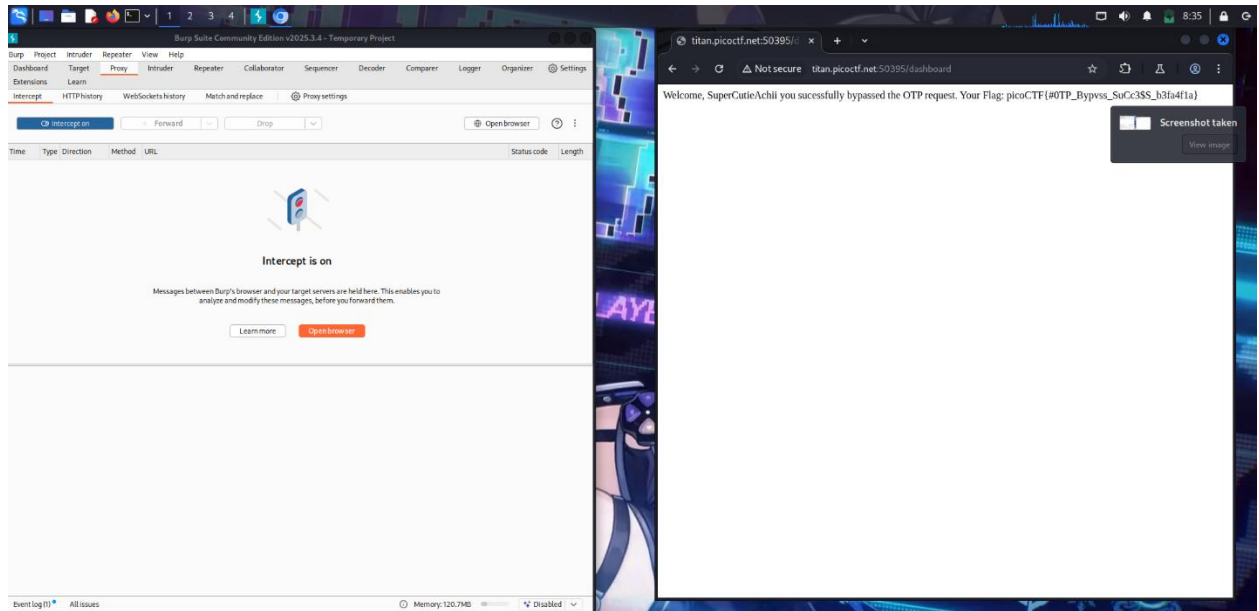
```
6 Origin: http://titan.picoc.tf.net:50395
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/136.0.0.0 Safari/537.36
10 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web
p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://titan.picoc.tf.net:50395/dashboard
12 Accept-Encoding: gzip, deflate, br
13 Cookie: session=
.eJwTjEsKwjAQQK9SsnZhalJTd-JCEFF2ACWTTGmwTUo-SBHv7hRlVvNm3nsz4_LKTuzucp6w6
rTzubrGrpBmZPi00fWRE8fByut5mAApeGtAvfCchC6tqoWdrBaKgUCQZA3lGnqPUVIexRYq6t
zhENeCiIGH6SkddEpvUK0xEzJDjc0Bo-9LzNgJNwcf00XkjD-illZMF4242xGCn--_PA-IA.aZ
xZJQ.HCKL29CGLCL3lpUMkrK9jlb4u2k
14 Connection: keep-alive
15
16 otp=1234567
```

13. Forwarded the modified request

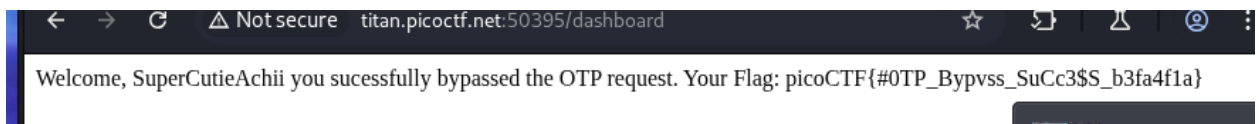




Saint Columban College
College of Computing Studies
Pagadian City



14. The server accepted the request and displayed the flag



Alternate Method (Repeater)

Instead of forwarding:

1. Right-clicked the OTP request

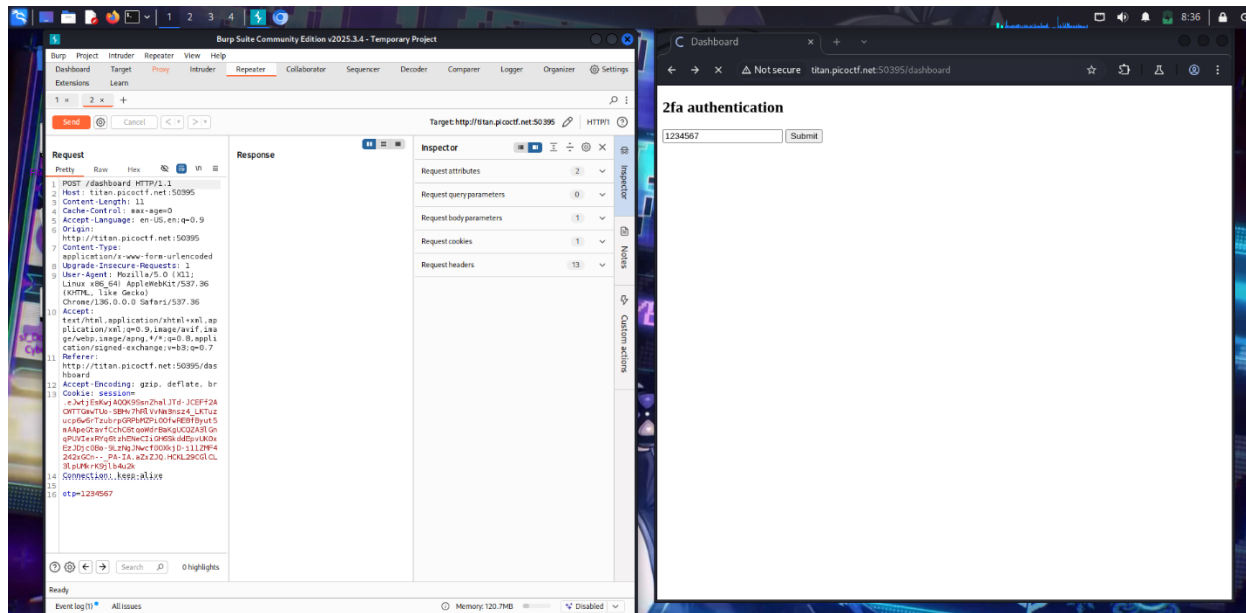
```
Pretty  Raw  Hex
6 Origin: http://titan.picoctf.net:50395
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/136.0.0.0 Safari/537.36
10 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web
p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://titan.picoctf.net:50395/dashboard
12 Accept-Encoding: gzip, deflate, br
13 Cookie: session=
.eJwtjEsKwjAQQK9SsnZha1Jtd-JCEff2ACWTTGmwTUo-SBHv7hRlVvNm3nsz4_LKTuzucp6w6
rTzubrpGRpbMZPi00fwRE8fByut5mAApeGt avfCchC6t qoWdrBaKgUCQZA3lGnqPUVlExRYq6t
zhENeCIiGH6SkddEpvUK0xEzJDjc0Bo-9LzNgJNwcf00XkjD-i1lZMF4242xGCn--_PA-IA.aZ
xZJQ.HCKL29CGLCL3lpUMkrK9jlb4u2k
14 Connection: keep-alive
15
16 http=1234567
```



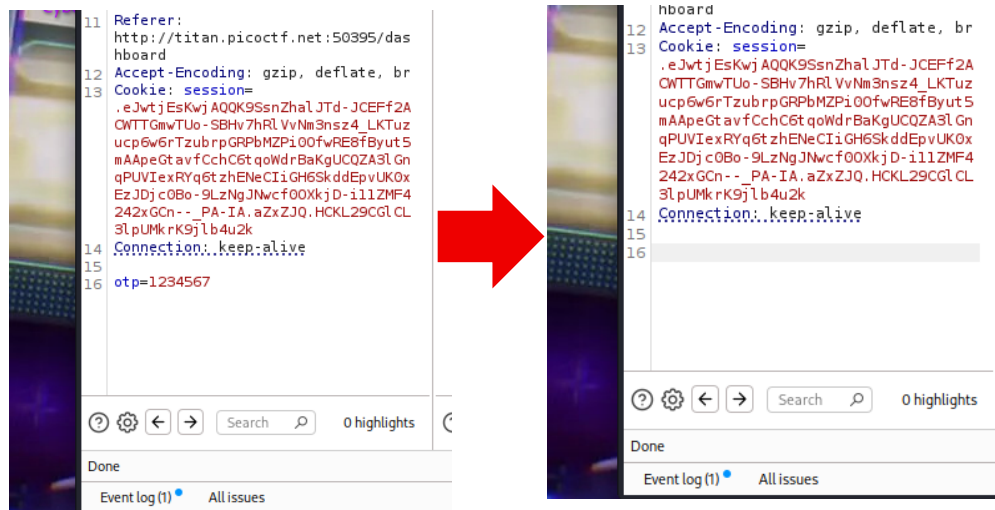

Saint Columban College
College of Computing Studies
Pagadian City



2. Sent it to **Repeater** (Right click on it ^ then send to repeater)

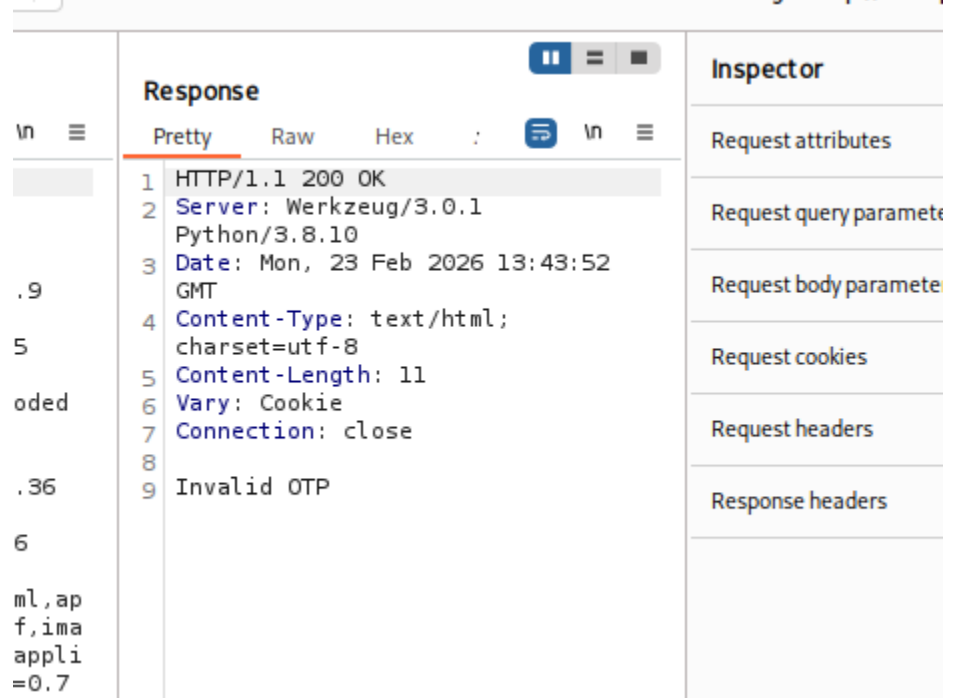


3. Removed the OTP value

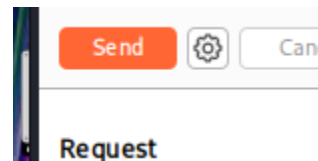




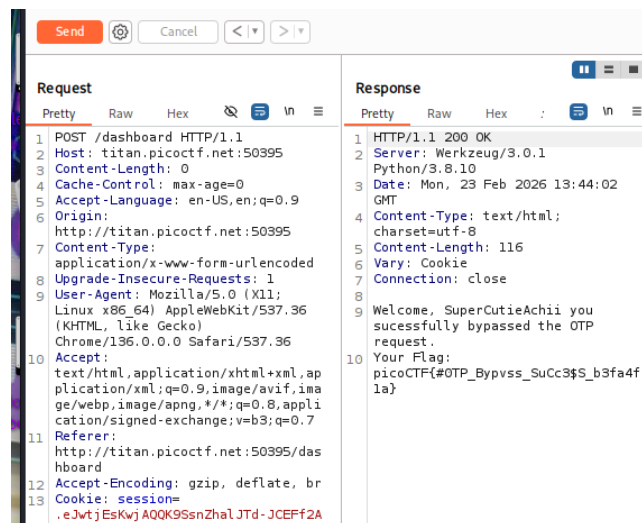
This happens when you don't:



4. Clicked Send



5. The server still returned the flag





V. Result

picoCTF{#0TP_Bypvss_SuCc3\$\$_b3fa4f1a}

```
← → ↻ ⚠ Not secure titan.picoctf.net:50395/dashboard ☆ 📄 🏠 🌐
Welcome, SuperCutieAchii you successfully bypassed the OTP request. Your Flag: picoCTF{#0TP_Bypvss_SuCc3$$_b3fa4f1a}

7 | Connection: close
8 |
9 | Welcome, SuperCutieAchii you
  | successfully bypassed the OTP
  | request.
10| Your Flag:
   | picoCTF{#0TP_Bypvss_SuCc3$$_b3fa4f
   | 1a}
```

VI. Explanation

What is Burp Suite?

Burp Suite is like a **magic window** that lets you see messages being passed between:

- Your browser
- The website's server

Analogy: Imagine you pass a note to your teacher. Burp lets you:

- Read the note
- Change the note
- Send it anyway

Normally, you can't do that.

What is Chromium in Burp?

Chromium is just a browser (like Chrome).

Burp gives you a special browser so:

- All traffic automatically goes through Burp



- Burp can see and control requests
If you use your normal browser:
- Burp won't intercept anything

What is a Proxy?

A **proxy** is a middleman.

Analogy: You → Proxy → Website

Burp sits in the middle and:

- Pauses requests
- Lets you inspect them
- Lets you modify them

What does “Intercept” mean?

Intercept means:

“Stop the message before it reaches the server.”

When Intercept is **ON**:

- Requests pause
- You can view or edit them

When **OFF**:

- Traffic flows normally

What is Repeater?

Repeater is like:

A replay button for web requests

It lets you:



- Send the same request again
- Modify it
- Test server behavior safely

Security testers use Repeater to:

- Test logic flaws
- Test authentication
- Test input validation

What is an OTP?

OTP means **One-Time Password**.

Example:

- Bank sends you a number
- You type it in
- You get access

OTP is supposed to:

- Prove it's really you
- Stop attackers

What went wrong in this challenge?

The website:

- Did NOT properly check the OTP on the server
- Trusted whatever the browser sent
- Allowed access even when OTP was missing

This is called a **logic flaw**.



Why removing the OTP worked?

The server:

- Only checked *if a request was sent (Did it actually tho?)*
- Did not verify the OTP value correctly

So when the OTP was:

- Wrong ✖
- Missing ✖

The server still said:

“Okay, you’re in.”

How this should be fixed (Real World)

Proper protection includes:

- Server-side OTP validation
- Rejecting missing or invalid OTPs
- Never trusting client input
- Adding rate limits
- Logging failed attempts

Key Lesson!!!

Security checks must happen on the server, not the browser.

This challenge teaches:

- How Burp intercepts traffic
- How attackers modify requests
- Why client-side trust is dangerous



VII. Conclusion

The IntroToBurp challenge introduces one of the most important tools in web security: **Burp Suite**.

Through this challenge, I learned:

- How web requests work
- How proxies intercept traffic
- How OTP logic can fail
- Why server-side validation is critical

This challenge marks the transition from **basic web inspection** to **active web exploitation**.

— **The Analyst: Hyposelenia**